THRIVE AFRICA CYBERSECURITY INTERNSHIP

FINAL SECURITY ASSESSMENT REPORT

Executive Summary

Week 1: Threat Modeling & Asset Inventory

The team established Ghana Maritime Defense Command (GMDC) as a defense and critical maritime-infrastructure scenario. The modeled environment considered command, communications, maritime surveillance, intelligence sharing and operational support, including a hybrid IT/OT context. Assets, likely entry points and STRIDE-style threats were considered to establish the baseline for later work. The scenario is not a verified inventory of a real organization.

Week 2: Reconnaissance & Enumeration

Kali Linux and Nmap were used in an authorized VirtualBox lab against

Metasploitable 2 at 192.168.1.3. Host discovery reported five live hosts. The target scan reported 13 open TCP ports and 875 closed TCP ports. Enumerated services included FTP, SSH, Telnet, SMTP, DNS, HTTP, SMB, NFS, MySQL, PostgreSQL, VNC, IRC and Tomcat. Observations included anonymous/plain-text FTP and disabled SMB signing. The target is intentionally vulnerable; results apply to the lab.

Week 3: Vulnerability Assessment

OpenVAS/Greenbone reported 64 actionable issues (12 Critical, 9 High, 37 Medium).

Nessus reported 71 findings (11 Critical, 7 High, 25 Medium) on the target address recorded in that report as 192.168.122.4.

Findings included a critical Ingreslock backdoor on TCP/1524 and an UnrealIRCd backdoor detection. Nikto identified outdated Apache/PHP versions, directory indexing, HTTP TRACE and missing defensive headers. The separate scanner counts must not be added as a unique total. A completed ZAP result was not present in the evidence reviewed.

Week 4: Risk Analysis & Prioritization

The team translated vulnerabilities into likelihood/impact risks and proposed mitigation actions. Available mitigation notes prioritize backdoors, default credentials, legacy cleartext remote services and Critical risks. They also require validation of exact versions and scanner evidence before applying vulnerability-specific fixes, followed by repeat scans to verify remediation.

Week 5: Security Governance & Policies

The team defined proposed roles for Management/Executive Authority, Security

Owner, System Administrator, Network Administrator, Asset/Data Custodian, Incident Response/IT Security and Authorized Users. Principles include accountability, least privilege, separation of duties, risk ownership, documented decisions and escalation. These are proposed controls for the GMDC scenario, not evidence of implemented governance.

Week 6: Incident Response & Security Operations

The team prepared an incident-response playbook, workflow diagram and Low/Medium/High/Critical classification table. The lifecycle covers detection/reporting, validation, classification/escalation, containment, eradication, recovery and lessons learned. Wazuh screenshots document setup and endpoint-agent/dashboard states only; they do not prove a real attack or a completed incident-response exercise.

Week 7: OSINT & Threat Intelligence

A limited passive review examined Thrive Africa's public website, programme descriptions, public contact channels and programme URLs. Potential misuse scenarios included fake internship messages, contact-channel impersonation and targeted phishing. No confirmed breach, leaked credentials, exposed internal document or technical vulnerability was established.

Objectives, Scope and Methodology

The project objective was to move from understanding assets and threats to technical discovery, vulnerability assessment, risk prioritization, governance, incident response and public-source intelligence.

In scope

GMDC scenario modeling; authorized VirtualBox reconnaissance and vulnerability scanning of Metasploitable 2; risk register and mitigation work; governance and incident-response documents; Wazuh lab setup evidence; and passive OSINT on Thrive Africa.

Out of scope

Production testing of GMDC or Thrive Africa; exploitation; password attacks; access to restricted systems or data; confirmation of a real-world breach; and technical scanning of Thrive Africa.

Methodology/tools evidenced

Kali Linux/Nmap for host and service discovery; OpenVAS/Greenbone and Nessus for infrastructure vulnerability scanning; Nikto for web-server assessment; Wazuh for endpoint monitoring lab setup; and public websites/search sources for OSINT. Some tools such as OWASP ZAP were explored, but the reviewed material does not support claiming a completed ZAP finding.

Consolidated Key Findings

KF-01: Exposed service surface: Nmap identified 13 open TCP ports on the Metasploitable 2 target, including remote access, file transfer, web, SMB, database and application services. A broad service surface increases the number of components requiring hardening and access control.

KF-02: Critical backdoor detections: Scanner evidence included Ingreslock on TCP/1524 and an UnrealIRCd backdoor detection. The Nessus report described the backdoor as capable of unauthenticated command execution with root-level impact on the lab host.

KF-03: Legacy/insecure configurations: Reports documented anonymous/plain-text FTP, legacy remote-access services, older Apache/PHP, disabled SMB signing, directory indexing and HTTP TRACE.

KF-04: High scanner finding volumes: Greenbone recorded 64 issues (12 Critical, 9 High, 37 Medium); Nessus recorded 71 (11 Critical, 7 High, 25 Medium). These are separate tool outputs and target contexts, not a deduplicated total.

KF-05: Governance and response framework: Weeks 5–6 produced proposed role ownership, escalation, incident classification, evidence handling and response procedures.

KF-06: OSINT social-engineering exposure: Public Thrive Africa programme and contact details could be copied into impersonation or phishing attempts. This is a potential risk scenario, not a confirmed incident.

Top Risks and Potential Impact

Critical — Backdoor or remote-code-execution exposure: could permit unauthorized command execution, privilege compromise and host takeover in the lab context.

High — Weak/default credentials and exposed database services: could enable unauthorized access, data disclosure or manipulation.

High — Legacy cleartext protocols and unnecessary services: could increase credential interception and unauthorized remote-access risk.

High — Outdated web software and insecure configuration: could increase the risk of web compromise, information disclosure and client-side security weaknesses.

High — Weak monitoring/escalation readiness (scenario risk): delayed detection or response could increase attacker dwell time and operational impact.

Moderate — Thrive Africa contact/programme impersonation: fake accounts or messages could deceive applicants or learners into sharing information, credentials or money. This rating is qualitative.

Recommended Mitigations

Immediate: isolate the intentionally vulnerable training host from untrusted networks; disable backdoor-affected services; remove unnecessary services; reset default/weak credentials; restrict database access; and verify exact software versions before selecting patches.

Reduce attack surface: disable Telnet and legacy Berkeley r-services; use encrypted administration such as SSH; replace plain-text FTP with secure file transfer; restrict SMB, VNC, database and application-server access; enable appropriate SMB signing; disable directory listing and HTTP TRACE where unnecessary; apply suitable security headers; and migrate unsupported software.

Governance: appoint security and asset owners; maintain asset and risk registers; enforce least privilege, strong unique credentials and MFA for privileged/remote access; document exceptions and approvals; and review access regularly.

Monitoring/response: maintain endpoint and log monitoring; assign alert triage and escalation owners; preserve evidence; rehearse incident response; test backups and recovery; and conduct post-incident reviews.

Thrive Africa OSINT safeguards: keep official contact details consistent; publish guidance for verifying internship/programme communications; provide a reporting channel for impersonation; train staff and learners on phishing and look-alike URLs; and periodically review public documents for accidental disclosure.

Verification: repeat authorized service enumeration and vulnerability scans after remediation, compare results with the baseline, validate closure and update the risk register. Correlate/deduplicate scanner findings.

Overall Security Posture

GMDC scenario/lab.

The Metasploitable 2 target displayed a Critical risk posture as configured, based on the scanner-reported critical backdoor-related and legacy-service findings. This does not establish the posture of any real GMDC production network.

Governance and incident-response documents are proposed controls whose implementation was not independently verified.

Thrive Africa OSINT case.

The limited passive review identified public information that could support impersonation or phishing. These observations are not technical vulnerabilities. No confirmed breach, leaked credentials or exposed internal document was established. The potential social-engineering exposure is best described as Low–Moderate/Moderate.

Consolidated judgement.

The project demonstrates an end-to-end educational assessment workflow. The strongest technical evidence relates to the deliberately vulnerable lab; all real-world security claims must remain within the defined scope.

Limitations and Validation Items.

GMDC is a fictional/scenario organization, not a verified real-world asset inventory. Metasploitable 2 is intentionally vulnerable. Week 2 identifies 192.168.1.3; the Week 3 Nessus report records 192.168.122.4. Preserve this difference unless the original evidence establishes how the environments relate. Scanner totals are not a unique deduplicated count. A completed ZAP result was not available in the reviewed evidence. Wazuh screenshots show setup/agent/dashboard states, not an attack simulation. Week 7 was passive OSINT only. Risk ratings are qualitative and should be validated by asset owners.

Conclusion

Group 19’s seven-week project demonstrates a structured security-assessment process: understand assets and threats, discover exposed services, assess vulnerabilities, prioritize risks, assign responsibilities, prepare incident response and communicate OSINT-related safeguards. The key technical lesson is the danger of backdoors, weak authentication, legacy

protocols and unsupported software. The organizational lesson is that technical findings require accountable owners, risk-based remediation, monitoring, escalation and recovery procedures.